

README: KIT DE ENCUESTA GQM + PRAGMATIC BSIMM15

Guía Integral de Uso del Kit Completo

Versión: 1.0

Fecha: Enero 21, 2026

Usuario: CISOs, Auditores, Consultores, Equipos de Gobernanza

Idioma: Español

¿QUÉ ES ESTE KIT?

Un **sistema integral y profesional** para evaluar, medir y mejorar la madurez de seguridad de software en tu organización, usando:

-  GQM (Goal-Question-Metric): Metodología de trazabilidad
-  PRAGMATIC: 9 criterios para validar utilidad de métricas
-  BSIMM15: Base de 121 organizaciones, 128 actividades
-  Templates: Excel, PowerPoint, Markdown, Checklist

Objetivo Final: Alcanzar 70 puntos NIS2 en 12 meses (Q1-Q4 2026)

CONTENIDO DEL KIT

Documentos de Referencia

Archivo	Propósito	Audiencia	Tiempo
1. marco_gqm_pragmatic.md	Arquitectura metodológica	CISOs, estrategas	1-2 h
2. matriz_pragmatic_completa.md	Evaluación 30+ actividades	Implementadores	30 min
3. resumen_ejecutivo_gqm.md	Hallazgos clave, roadmap	Dirección	15 min
4. cuaderno_trabajo_gqm.md	Templates operativos	Equipos técnicos	2-3 h
5. mapeo_gqm_normativo.md	Trazabilidad regulatoria	Auditores	1 h
6. plantilla_excel_igm_roi.md	Cálculo métricas y ROI	Analistas	2-3 h
7. plantilla_ppt_ejecutivo.md	Reporte trimestral	CISOs/Directores	4-6 h
8. README.md	Este archivo (guía de uso)	Todos	15 min

Total Documentos: 8 archivos .md descargables

CÓMO USAR ESTE KIT

Escenario 1: "Soy CISO, necesito implementar BSIMM en Q1"

Paso 1: Lectura Rápida (1 hora)

1. Lee RESUMEN EJECUTIVO (15 min)
→ Entiende problema, solución, TOP 10 actividades
2. Lee MARCO INTEGRATIVO Parte I-II (30 min)
→ Aprende GQM (3 niveles) + PRAGMATIC (9 criterios)
3. Escanea MATRIZ PRAGMATIC TOP 10 (15 min)
→ Ve actividades CR1.4 (91), SM1.4 (89), DM1.1 (89)

Paso 2: Planificación (2 horas)

1. Completa CUADERNO DE TRABAJO Partes I-II (2 h)
 - Define tu GQM local (GOAL, QUESTIONS, METRICS)
 - Evalúa actividades contra PRAGMATIC
2. Resultado: Matriz GQM + PRAGMATIC personalizada para tu org

Paso 3: Presentación a Dirección (1 hora)

1. Prepara PLANTILLA POWERPOINT slides 1-12 (45 min)
 - Copia estructura sugerida
 - Reemplaza con datos tu org
2. Presenta en 20 min (15 min)
 - Usa RESUMEN EJECUTIVO como narrative
 - Apunta a TOP 10 PRAGMATIC como justificación
3. Objetivo: Aprobación presupuesto €26k Q1

Paso 4: Ejecución (90 días)

1. Implementa TOP 4 actividades Q1:
 - CR1.4: SAST Tools (€6k)
 - SM1.4: Checkpoints (€5k)
 - EM1.3: Dashboard (€2k)
 - DM1.1: Infra Auto (€8k)
2. Usa PLANTILLA EXCEL para tracking:
 - Entrada: datos de implementación
 - Cálculo: IGM score automático
 - Output: Dashboard + ROI
3. Hito Q1: Score 56 → 71 (+15 puntos)

Escenario 2: "Soy Director, necesito aprobar inversión"

Paso 1: Lectura Ejecutiva (15 minutos)

1. Lee RESUMEN EJECUTIVO COMPLETO
 - Problema: 128 actividades sin priorización
 - Solución: TOP 10 PRAGMATIC = 80% impacto
 - Financiero: €258k para 368% ROI
2. Conclusión: ¿Apruebo o no?
 - Sí si: Riesgo ciberseguridad es prioridad
 - Sí si: ROI 368% es aceptable
 - Sí si: Timeline 12 meses es realista

Paso 2: Decisión

Preguntas Clave para CISO:

- ☐ ¿TOP 10 PRAGMATIC son realmente prioritarios?
- ☐ ¿€258k es presupuesto realista?
- ☐ ¿Equipo puede ejecutar en 12 meses?
- ☐ ¿Beneficios €1.21M son conservadores?

Si 3+ respuestas = SÍ → APRUEBA

Si NO → Enviar CISO a Paso 1 (Escenario 1)

Paso 3: Autorización

Email a CISO:

"Aprobado:

- Presupuesto: €258k anual (2026)
- Timeline: Q1-Q4 2026
- Reportes: Trimestrales a Board
- Puntos de control: Q1 (71), Q2 (81), Q3 (88), Q4 (90+)"

Escenario 3: "Soy Auditor, necesito validar NIS2"

Paso 1: Mapeo Regulatorio (1 hora)

1. Lee MAPEO GQM NORMATIVO (30 min)
 - Cómo cada Pregunta GQM conecta a NIS2 Medidas
 - Cobertura: 8/10 medidas (80%)
2. Obtén lista de PREGUNTAS GQM implementadas (30 min)
 - Ask CISO: ¿Cuáles de las 30 preguntas están respondidas?
 - Mapea a tu checklist de compliance

Paso 2: Validación de Implementación

Para cada Pregunta GQM implementada:

- ☐ ¿Existe política/procedimiento formal documentado?
- ☐ ¿Se ejecuta operativamente (más de 1 instancia)?
- ☐ ¿Se ha auditado internamente el último año?
- ☐ ¿Se han cerrado hallazgos previos?
- ☐ ¿Alinea a requisito NIS2/ENS/GDPR específico?

Si 5/5: COMPLIANT 

Si 3-4/5: PARCIAL 

Si <3/5: NO COMPLIANT 

Paso 3: Opinión de Auditoría

Reporte:

"Evaluación BSIMM15 + GQM + PRAGMATIC muestra:

- ✓ Implementación de X/30 preguntas GQM
- ✓ Cobertura NIS2: 8/10 medidas (80%)
- ✓ Status: Camino correcto a compliance 2026

- ⚠ Brechas pendientes:
- Medida 5 (Criptografía): Parcial
 - Medida 6 (Backup): No evaluado

RECOMENDACIÓN: Plan de remediación en Q2-Q3"

Escenario 4: "Soy Implementador, necesito pasos concretos"

Paso 1: Preparación (Semana 1)

1. Descarga CUADERNO DE TRABAJO
2. Lee Parte I (GQM): 30 min
3. Lee Parte II (PRAGMATIC): 30 min
4. Reúnete con CISO: Clarifica GOAL local

Paso 2: Evaluación (Semana 2-3)

1. Completa Plantilla GQM (Parte I Cuaderno)
 - Llena GOAL, QUESTIONS, METRICS
 - Resultado: ~10 métricas clave
2. Completa Plantilla PRAGMATIC (Parte II Cuaderno)
 - Evalúa cada métrica vs 9 criterios
 - Califica 0-100 cada criterio
 - Suma: Score PRAGMATIC por métrica
3. Resultado: Matriz GQM + PRAGMATIC para tu org

Paso 3: Priorización (Semana 4)

1. Selecciona PRAGMATIC ≥85 (Quick Wins Q1)
 - Implementar en 90 días
 - Presupuesto ~€25k
2. Aparta PRAGMATIC 70-84 (Baseline Q2-Q3)
 - Implementar con CISO validation
 - Presupuesto ~€70k
3. Descarta PRAGMATIC <70 (o aplaza Q4+)

Paso 4: Implementación (Semana 5+)

Para cada actividad TOP 10:

1. Designa propietario (owner)
2. Estima duración (típicamente 30-45 días)
3. Asigna presupuesto
4. Crea tickets en Jira/Azure DevOps
5. Sigue CUADERNO Parte IV (Roadmap)

Medir cada 2 semanas:

- % completación
- Presupuesto gastado
- Riesgos emergentes

Paso 5: Tracking (Permanente)

1. Usa PLANTILLA EXCEL para tracking:
 - Hoja 1: Datos entrada (actividades + status)
 - Hoja 2: IGM Calculation (score automático)
 - Hoja 3: ROI (beneficios)
 - Hoja 4: Dashboard (KPIs)
2. Reporta mensualmente a CISO:
 - % avance vs plan
 - Presupuesto vs actual
 - Riesgos y mitigaciones
3. Reporte trimestral a Dirección:
 - Usa PLANTILLA POWERPOINT (12 slides)
 - 20 minutos presentación
 - Incluye recomendaciones next quarter

FLUJO RÁPIDO: 8 SEMANAS DE IMPLEMENTACIÓN

Semana 1-2: Lectura + Planning

- CISO lee Resumen Ejecutivo (1h)
- Dirección revisa hallazgos + ROI (30 min)
- CISO reúne equipo: Aprobación GOAL + presupuesto (1h)
- Implementador comienza Cuaderno (2h)

Semana 3-4: Evaluación QQM + PRAGMATIC

- Completar Plantilla QQM (Cuaderno Parte I) (2h)
- Completar Plantilla PRAGMATIC (Cuaderno Parte II) (1h)
- Consolidar matriz QQM + PRAGMATIC (30 min)
- Presentación interna a CISO (30 min)

Semana 5: Kick-Off Ejecutivo

- Montar steering committee (1h)
- Asignar propietarios TOP 4 actividades (1h)
- Crear Jira tickets (1h)
- Setup PLANTILLA EXCEL (1h)

Semana 6-8: Ejecución Q1

- ☐ CR1.4 (SAST): Implementar, test, validate (45 días)
- ☐ SM1.4 (Checkpoints): Integrar en CI/CD (30 días)
- ☐ EM1.3 (Dashboard): Crear + populate (20 días)
- ☐ DM1.1 (Infra Auto): Setup automation (35 días)

Paralelo:

- ☐ Actualizar PLANTILLA EXCEL semanalmente
- ☐ Reportar a CISO (bi-semanal)
- ☐ Resolver riesgos operativos

Semana 8: Medición + Reporteo

- ☐ Calcular IGM final Q1 (PLANTILLA EXCEL)
- ☐ Extraer datos para PLANTILLA POWERPOINT
- ☐ Crear slides 1-12 (4-6h)
- ☐ Ensayar presentación (1h)
- ☐ Presentar a Dirección (20 min)
- ☐ Documenta lecciones aprendidas

ESTRUCTURA DE ARCHIVOS DESCARGABLES

KIT_GQM_PRAGMATIC_BSIMM15/

- └─ 01_MARCO_INTEGRATIVO
 - └─ marco_gqm_pragmatic.md (1,500 líneas)
- └─ 02_MATRIZ_PRAGMATIC
 - └─ matriz_pragmatic_completa.md (1,200 líneas)
- └─ 03_RESUMEN_EJECUTIVO
 - └─ resumen_ejecutivo_gqm.md (600 líneas)
- └─ 04_CUADERNO_TRABAJO
 - └─ cuaderno_trabajo_gqm.md (800 líneas)
- └─ 05_MAPEO_NORMATIVO
 - └─ mapeo_gqm_normativo.md (900 líneas)
- └─ 06_PLANTILLAS_OPERATIVAS
 - └─ plantilla_excel_igm_roi.md (descripción completa Excel)
 - └─ plantilla_ppt_ejecutivo.md (descripción completa PowerPoint)
 - └─ README.md (este archivo)
- └─ 07_DOCUMENTOS_SOPORTE
 - └─ INDICE_GENERAL.md
 - └─ ENTREGA_COMPLETA.md
 - └─ Infografía GQM+PRAGMATIC.png

REFERENCIAS CRUZADAS

Necesidad	Documento	Sección
Entender GQM	Marco Integrativo	Parte I
Entender PRAGMATIC	Marco Integrativo	Parte II
Ver ejemplos detallados	Marco Integrativo	Parte III
Evaluar actividades	Matriz Pragmatic	Tablas Evaluación
Ver TOP 10	Resumen Ejecutivo	Hallazgos Clave
Definir tu GQM	Cuaderno Trabajo	Parte I-II
Validar compliance	Mapeo Normativo	Tablas Mapeo
Calcular IGM	Plantilla Excel	Hoja 2
Calcular ROI	Plantilla Excel	Hoja 3
Crear reporte	Plantilla PowerPoint	Slides 1-12

FAQ (PREGUNTAS FRECUENTES)

P1: ¿Debo leer todos los documentos?

R: No. Depende de tu rol:

- **CISO:** Lee Resumen + Marco Integrativo
- **Director:** Lee solo Resumen Ejecutivo (15 min)
- **Implementador:** Lee Cuaderno + Plantillas
- **Auditor:** Lee Mapeo Normativo + Matriz Pragmatic

P2: ¿Cuánto tiempo toma implementar TODO?

R:

- **Lectura total:** 8-10 horas
- **Planning + evaluación:** 6-8 horas
- **Implementación Q1:** 90 días
- **Reporting:** 4-6 horas por trimestre

Total Año 1: ~40-50 horas gestión + 90 días ejecución

P3: ¿Qué pasa si mi presupuesto es menor a €258k?

R:

1. Implementa SOLO TOP 4 actividades Q1 (€26k)
 - Resultado: Score 56 → 71 (+15 puntos)
 - ROI: 1,515%

1.

Aplaza Q2-Q4 para años siguientes

2.

Expected end-2026: Score 71 (vs. target 70) 

Aplaza Q2-Q4 para años siguientes

Expected end-2026: Score 71 (vs. target 70) 

P4: ¿Cómo valido que las métricas son correctas?

R:

1. Cada métrica tiene PRAGMATIC score (0-100)
2. Si <70: Rechaza o reemplaza
3. Si ≥85: Adopta inmediatamente
4. Si 70-84: Evalúa ROI antes de adoptar

Ver MATRIZ PRAGMATIC COMPLETA para evaluación de cada actividad.

P5: ¿Qué pasa después de Q1?

R:

1. Reporte a Dirección (PLANTILLA POWERPOINT)
2. Lecciones aprendidas (CUADERNO Parte VIII)
3. Rebaselining (PLANTILLA EXCEL)
4. Plan Q2 (del RESUMEN EJECUTIVO)
5. Repetir ciclo

P6: ¿Aplica este kit a otras organizaciones?

R: SÍ.

- GQM es agnóstico (usa PRAGMATIC para evaluar cualquier métrica)
- BSIMM15 es estándar global (121 orgs, 15 años datos)
- NIS2/ENS/GDPR es regulatorio España (adaptable otras regiones)

Personalización: Usa CUADERNO TRABAJO Parte I para customizar GOAL local.

P7: ¿Quién debe estar en steering committee?

R:

-  CISO (propietario programa)
-  CTO/VP Engineering (implementación técnica)
-  CFO/Analyst (financiero)
-  Compliance/Risk officer
-  Principales application owners

Reuniones: Bi-semanal (30 min status, 30 min riesgos)

P8: ¿Cómo reporto progreso a auditoría?

R:

1. Usa MAPEO NORMATIVO para trazabilidad → NIS2/GDPR
2. Referencia PREGUNTA GQM específica implementada
3. Proporciona evidencia (documento, métrica, logs)
4. Valida que PRAGMATIC ≥ 70 para cada métrica

Ver MAPEO NORMATIVO sección "Auditoría: Validación de Cumplimiento"

SOPORTE Y ESCALACIÓN

Preguntas sobre Metodología

- Consulta MARCO INTEGRATIVO (Partes I-II)

Preguntas sobre Actividades Específicas

- Consulta MATRIZ PRAGMATIC COMPLETA (tablas evaluación)

Preguntas sobre Implementación

- Consulta CUADERNO DE TRABAJO (Partes III-VIII)

Preguntas sobre Regulatorio

- Consulta MAPEO GQM NORMATIVO (tablas mapeo)

Preguntas sobre Financiero

- Consulta PLANTILLA EXCEL (Hojas 2-5)

Preguntas sobre Presentación

- Consulta PLANTILLA POWERPOINT (Slides 1-12)

Pregunta No Contestada

- Contactar: CISO@organizacion.es

CHECKLIST DE IMPLEMENTACIÓN

Pre-Inicio (Semana -2)

- ☐ Descargar todos 8 documentos .md
- ☐ CISO revisa RESUMEN EJECUTIVO
- ☐ Dirección aprueba GOAL nacional + presupuesto
- ☐ Identificar steering committee
- ☐ Asignar implementador principal

Inicio (Semana 1)

- ☐ Kick-off meeting con equipo (1h)
- ☐ Socializar por qué GQM + PRAGMATIC
- ☐ Distribuir CUADERNO TRABAJO
- ☐ Crear canal comunicación (Slack, Teams, email)

Planning (Semana 2-3)

- ☐ Completar Plantilla GQM
- ☐ Completar Plantilla PRAGMATIC
- ☐ Consolidar matriz GQM + PRAGMATIC personalizada
- ☐ Validar con CISO + stakeholders

Setup (Semana 4-5)

- ☐ Crear PLANTILLA EXCEL (copiar estructura recomendada)
- ☐ Setup PLANTILLA POWERPOINT (copiar slides base)
- ☐ Crear Jira/DevOps tickets para TOP 4 Q1
- ☐ Asignar owners y presupuesto

Ejecución (Semana 6-8+)

- ☐ Monitorear progreso bi-semanal
- ☐ Actualizar PLANTILLA EXCEL semanalmente
- ☐ Reportar a CISO (bi-semanal)
- ☐ Escalación riesgos si aplica

Cierre Q1 (Fin Semana 12)

- ☐ Calcular IGM final (PLANTILLA EXCEL)
- ☐ Completar PLANTILLA POWERPOINT
- ☐ Presentar a Dirección (20 min)
- ☐ Documentar lecciones aprendidas
- ☐ Plan Q2 (basado en RESUMEN EJECUTIVO roadmap)

CONCLUSIÓN

Este kit proporciona **todo lo necesario** para:

- ✓ **Evaluar** madurez actual con rigor metodológico (GQM + PRAGMATIC)
- ✓ **Priorizar** inversión en TOP 10 actividades (80% impacto)
- ✓ **Justificar** presupuesto con ROI claro (368% anual)
- ✓ **Implementar** en fases (Q1-Q4 2026)
- ✓ **Reportar** progreso a Dirección trimestralmente
- ✓ **Validar** compliance regulatorio (NIS2, ENS, GDPR)

No requiere herramientas costosas.

No requiere consultor externo.

Diseñado para PYME a multinacional.

Contexto España 2026.

PRÓXIMOS PASOS

3. Descarga los 8 documentos .md
4. Lee RESUMEN EJECUTIVO (15 min)
5. Presenta a Dirección y consigue aprobación
6. Comienza con CUADERNO TRABAJO (semana 1)
7. Implementa TOP 4 Q1 (90 días)
8. Reporta progreso Q1 usando POWERPOINT
9. Continúa Q2-Q4 según roadmap

¡Comienza tu transformación GQM + PRAGMATIC hoy!

Versión: 1.0

Fecha: Enero 21, 2026

Estado:  LISTO PARA USAR

FIN DEL README